Romel Paper Revisions

Targeted locations, suggested wording, and evidence gaps | 24 October 2026

Edit the manuscript yourself using this guide. It does not replace the thesis, rewrite unrelated chapters, or change the Solis PDFs. Every Find anchor below is checked against the supplied current DOCX. Source paragraph numbers are one-based body-paragraph indexes, NOT printed page numbers. Word pagination depends on layout; update the thesis table of contents and printed pages after editing.

Release wording: use 'the revised implementation' for this local work. Write 'the deployed system' only after migration/backend/frontend deployment and controlled verification. Do not turn local mocked tests into claims of production security or extraction accuracy.

Edit	Where	Purpose
R1	Chapter III: Data Privacy and Ethical Considerations	Sensitive-data inventory; distinguish login, file encryption and CSV handling
R2	Chapter III: Data Privacy / Testing	Download and password-assisted upload behavior, audit scope and limits
R3	Chapter II / III / IV recommendation passages	Correct Decision Tree claims to Weighted Recommendation Scoring
R4	Chapter III: validation, account flow and algorithms	Separate parsing, identity matching and scholarship authorization
R5	Figures 3.1-3.8 and corresponding explanations	Manual/automatic activation, profile-only review and protected-download paths
R6	Chapter III Testing / Chapter IV evidence	Traceable test cases, narrow reproduced gaps and unverified production checks
R7	Chapter I limitations / Chapter III deployment / Chapter V	Keep real limitations, add verified local revision without certification claims

R1. Name the Sensitive Information

Where: Chapter III > Data Privacy and Ethical Considerations

Find: "Sensitive information handled by the system may include" | Source paragraph(s): 248

Action: expand this paragraph or insert a short inventory immediately after it. Do not describe every field as encrypted by the application just because Supabase encrypts hosted storage. The editable profile indexes guardian/contact/address and academic fields; family-income ranking is not implemented by the current recommendation function.

Category	Specific information / artifacts
Personal / identity	Student number, name, birth date, photo, signature, guardian identity/contact
Contact / address	Email, mobile, street, barangay, municipality/city, province, postal code
Academic	Course, college, year/section, COR, ROG, GWA and document-derived academic information
Scholarship	Applications, grantor relationships, waitlist, commitment, cycle progress, decisions and materials
Profile / financial declarations	Filled profile and any financial/family declarations actually present in submitted attachments; do not invent a structured bank-account subsystem
Documents / reports	Identity files, revisions, signed SOE, requirements, personalized forms, reports and file inventory
Authentication / audits	Provider credential/session data, account/security state and audit records; not recoverable stored download passwords

Suggested wording: The system handles personal and identification information, contact and address details, academic records, scholarship applications and workflow records, profile forms, photographs, signatures, and uploaded scholarship documents. Reports and file inventories may also contain sensitive information. Any financial or family declaration actually contained in a submitted document is treated as sensitive document content. Access is limited by verified identity, role, permission, ownership and scholarship relationship. Downloaded copies receive a separate file-protection layer; this does not mean that each database field is separately encrypted by the application.

R2. Explain Download Protection, Not Just Login

Where: Chapter III > Data Privacy and Ethical Considerations > uploaded files

Find: "Uploaded student and scholarship documents are stored using Supabase Storage." | Source paragraph(s): 249

Action: retain the private-storage/authorization explanation, then add the file-protection behavior below. Keep antivirus and retention limitations. Public images and empty templates are excluded.

Suggested wording: In the revised implementation, ordinary PDF download copies are encrypted using explicitly selected AES-256. CSV, Excel, image and other original-format attachments are placed in AES-256 password-protected ZIP archives. Signed PDFs are packaged without rewriting their original signed bytes. Stored originals and historical versions are preserved. Each official download uses a fresh, randomly generated 32-character password that the user must save before continuing. A forgotten password cannot be recovered; an authorized user can create a new protected copy. Download passwords are not account passwords or Student IDs.

Suggested wording: Authenticated previews remain readable inside the application. Official download actions use protected copies, but file encryption cannot prevent an authorized viewer from taking screenshots, copying displayed content, saving a browser preview, or sharing a password. Copying a password may also place it in the user's device clipboard history. This is a limitation of the user's device and readable previews, not a claim of digital-rights management.

Suggested wording: When a PDF re-upload requires a password, the back-end uses the supplied password temporarily to decrypt a processing copy before document validation. The original uploaded bytes are kept privately, and a separate private preview or processing copy may be stored. The password is not retained. A transformed processing copy is not represented as preserving the original digital signature; the original signed artifact remains authoritative.

Where: Chapter III > Data Privacy and Ethical Considerations > logs

Find: "The system maintains selected security and activity records" | Source paragraph(s): 250

Suggested wording: The revised download audit records the authorized actor, resource identifier, source-byte fingerprint, original format, protection method, timestamp and preparation result. Passwords and document contents are excluded. The download-audit table is append-only and service-role-only, and its events are available through the existing Root audit interface. A prepared event means that an encrypted copy was generated and audited; it does not prove the browser saved or opened it. Document previews do not create export-history entries, and downloading signup documents does not satisfy the administrator's preview requirement.

R3. Correct the Recommendation Algorithm

Where: Chapter II > Technical Background > description of the present system

Find: "In the context of this study, the developed system uses a rule-based Decision Tree" | Source paragraph(s): 120

Where: Chapter III > System Modules > 3. Scholarship Recommendation Module

Find: "The scholarship recommendation module helps students identify scholarship programs" | Source paragraph(s): 262

Where: Chapter III > System Modules > 4. recommendation-mechanism heading

Find: "4. Rule-Based Decision Tree Scholarship Recommendation Mechanism" | Source paragraph(s): 266

Action: replace the present-system Decision Tree claims and unsupported list of automatic ranking fields. Rename Module 4 to 'Weighted Recommendation Scoring Mechanism'. Keep genuine Decision Tree research in related literature, but explicitly contrast it with this system. Do not replace the working algorithm to fit old wording.

Suggested wording: The system uses Weighted Recommendation Scoring, a deterministic ranking method rather than a trained Decision Tree. Candidates are excluded when applications are blocked or disabled, or when the student's GWA does not meet the required minimum. Eligible candidates receive points for grade fit, normalized scholar-roster popularity, location fit and announcement completeness. The resulting score orders the suggestions. The score is not a probability or a percentage of scholarship acceptance, and final application authorization and approval remain separate.

Actual factor	Implemented computation
Grade fit	min(40, 24 + 12 x max(0, minimum GWA - student GWA)); lower eligible GWA is better
Roster popularity	rosterCount / maximum candidate rosterCount x 22; uses 30 when student GWA <= 1.75; zero if maximum is zero
Location fit	Up to 25: province, city and barangay matches; Pampanga-to-Bulacan gets lower priority. No-location fallback is 8; other configured province can contribute 2.
Announcement completeness	8 baseline points plus 2 if a supported image field exists; not a family-income/profile-completion percentage
Ordering	Sum factor points, sort descending. Candidate mix can change popularity normalization. No trained model or learned classification accuracy.

Important distinctions: eligibility/application scope uses exact approved province-municipality pairs and ignores barangay; recommendation location ranking may use barangay. Family income, course, year and achievements are not weighted ranking inputs in scholarship_rules.recommend_scholarships. The browser also has a weighted local fallback; neither implementation is a Decision Tree.

Rationale you can state: a transparent, configurable point-based method supports explainable ordering using available records without requiring a labeled historical training dataset. This is an engineering rationale, not evidence that the method outperforms machine-learning models.

Other Present-System Recommendation Passages to Align

Where: Chapter III > Back-End Technology

Find: "The back-end of the system was developed using Python" | Source paragraph(s): 303

Where: Chapter III > Scholarship Recommendation Mechanism

Find: "The system provides scholarship recommendations using a rule-based Decision Tree" | Source paragraph(s): 357

Where: Chapter III > development/prototyping description

Find: "The rule-based Decision Tree recommendation algorithm and the Record Linkage" | Source paragraph(s): 437

Where: Chapter IV > System Presentation > recommendation module

Find: "The Scholarship Recommendation Module compares student information" | Source paragraph(s): 469

Replace only the recommendation description in these passages with 'Weighted Recommendation Scoring with predefined eligibility filters'. Search remaining 'Decision Tree' occurrences: revise claims about THIS system, but do not erase the names of algorithms actually used by cited studies. Also remove unsupported present-system income/course/year/achievement ranking claims from Modules 3 and 4.

Decision Tree search hit, source paragraph 120: In the context of this study, the developed system uses a rule-based Decision Tree algorithm that evaluates predefi...

Decision Tree search hit, source paragraph 132: Decision Tree algorithms may be used for scholarship recommendation because they classify data through clear decisi...

Decision Tree search hit, source paragraph 133: Daluyon and Bilog (2025) developed a Scholarship Management Information System using machine learning models and fo...

Decision Tree search hit, source paragraph 134: The basic recommendation process involves collecting student data, preparing the dataset, comparing student attribu...

Decision Tree search hit, source paragraph 167: Alfonso et al. (2025) developed Mediskolar, a web-based scholarship management system for Marikina City that incorp...

Decision Tree search hit, source paragraph 179: Daluyon and Bilog (2025) developed a Scholarship Management Information System using machine learning models. Their...

Decision Tree search hit, source paragraph 188: The reviewed literature and studies show that digital scholarship systems can improve application processing, recor...

Decision Tree search hit, source paragraph 263: The recommendation mechanism uses a rule-based Decision Tree algorithm based on predefined scholarship eligibility ...

Decision Tree search hit, source paragraph 266: 4. Rule-Based Decision Tree Scholarship Recommendation Mechanism...

Decision Tree search hit, source paragraph 303: The back-end of the system was developed using Python, a general-purpose programming language (Python Software Fou...

Decision Tree search hit, source paragraph 357: The system provides scholarship recommendations using a rule-based Decision Tree algorithm based on predefined scho...

Decision Tree search hit, source paragraph 437: In this phase, the researchers developed the core modules of the system, including scholarship posting, application...

Decision Tree search hit, source paragraph 469: The Scholarship Recommendation Module compares student information with the eligibility requirements of available s...

Decision Tree search hit, source paragraph 609: Alfonso, J. C. M., Carvajal, J. E. R., Herrera, M. R., Morante, M. J. G., Solomo, M. V. S., Angel, R. M. D., & Ragu...

R4. Explain Three Separate Processes

Where: Chapter III > User Registration, Authentication, and Access Control

Find: "The system uses Supabase Auth together with FastAPI-based authentication" | Source paragraph(s): 349

Suggested wording: Account creation combines identifier availability and uniqueness checks, document parsing and validation, authentication-provider registration, email confirmation and account activation. In manual account-review mode, the administrator must preview every applicable signup document before the single Approve Account action. In automatic mode, confirmation activates the account only when all applicable signup documents meet the required system-approved state. A welcome email is attempted once for a newly activated account. Email delivery failure does not undo activation.

Where: Chapter III > System Modules > Validation Module

Find: "5. Validation Module" | Source paragraph(s): 271

Suggested wording: Document parsing first attempts embedded PDF text and layout extraction using pdfplumber. If usable text is absent, the document is converted to images for OCR. Field patterns, layout/table interpretation and document-specific policy checks are then applied. COR and ROG validity is determined by these checks, not by Levenshtein similarity. Valid school-document uploads are system-approved; the Student Application Profile always requires authorized administrator review. A student identity document is required at account creation, but is not a recurring semester requirement. An active student's optional identity replacement is automatically accepted through the existing upload policy.

Retain the already-correct duplicate-field and threshold paragraphs. Actual weighted fields: Student ID .32, full name .30, email .10, phone .08, course .08, year .04, city .04, province .04. Missing values are excluded and available weights renormalized. Exact Student ID is a strong match; exact email/phone requires name similarity >= .72; fuzzy duplicate flag requires name >= .82 and weighted score >= .84. Birth date and school are not weighted fields. Fuzzy matching is not only a fallback for missing IDs. Identity similarity flags and cycle-aware award/commitment guards are separate controls.

Do not add measured document-extraction accuracy, precision, recall or algorithm-superiority claims without a labeled authorized test set and actual results. Synthetic tests and successful compilation cannot establish real COR/ROG OCR accuracy.

R5. Flowcharts and Exact Captions

Where: Chapter III > system-flowchart figures

Find: "Figure 3.1: Student Account Registration and Authentication Flowchart" | Source paragraph(s): 380

Where: Chapter III > system-flowchart figures

Find: "Figure 3.2: Student Profile and Document Verification Flowchart" | Source paragraph(s): 399

Where: Chapter III > system-flowchart figures

Find: "Figure 3.6: Scholarship Grantor Portal Flowchart" | Source paragraph(s): 417

Where: Chapter III > system-flowchart figures

Find: "Figure 3.7: Administrator Portal Flowchart" | Source paragraph(s): 421

Where: Chapter III > system-flowchart figures

Find: "Figure 3.8: Scholarship Requirements and Completion Flowchart" | Source paragraph(s): 424

Use the revised Mermaid source in docs/SystemFlowchart.md. Figure 3.1 must show manual versus automatic activation, pending and correction endings, preview gating and one welcome-email attempt. Figure 3.2 must separate automatic COR/ROG/active-ID handling from profile-only administrator review; remove the old generic manual-document switch branch. Grantor/Admin/materials figures should connect official downloads to the protected-download subprocess and password-assisted re-upload subprocess. Use matching connector labels and explicit cancel/denied/failed/success endings. Do not treat a return connector as an unexplained dead end.

Where: Chapter III > explanation below Figure 3.1

Find: "Figure 3.1 presents the student account registration and authentication process" | Source paragraph(s): 382

Suggested wording: Figure 3.1 separates email confirmation from account activation. After confirmation, Manual Account Review keeps the account pending until the administrator previews the applicable signup documents and approves the account. Automatic Account Review activates the account only when all applicable signup requirements are system-approved. Missing or invalid requirements keep the account pending. Newly activated accounts receive one welcome-email attempt, and repeated callbacks do not create another activation.

Where: Chapter III > explanation below Figure 3.2

Find: "Figure 3.2 presents the process for completing and verifying" | Source paragraph(s): 400

Suggested wording: Figure 3.2 distinguishes document-specific validation from profile review. Valid COR and ROG uploads are approved automatically after the existing checks; identity verification is required at signup and is not renewed each semester. The Student Application Profile remains pending until an administrator decides on its latest revision. Authorized previews and protected downloads are separate operations, and an encrypted PDF re-upload may require a temporary file password for processing.

R6. Add Traceable Security Test Evidence

Where: Chapter III > Testing

Find: "In this phase, the developed system underwent testing procedures" | Source paragraph(s): 218

Where: Chapter III > Table 1 explanation

Find: "Table 1 presents the summary of the selected core test cases" | Source paragraph(s): 224

Suggested wording: Additional local security-regression tests evaluated protected download preparation, AES-256 PDF and ZIP behavior, wrong or missing passwords, preservation of original bytes, password-assisted PDF uploads, selected authorization boundaries, audit failures, preview separation and CSV formula-prefix escaping. The local backend suite completed 378 test methods, including 30 focused protection methods. Separate local PostgreSQL-compatible tests checked permissions and append-only audit behavior. Responsive browser tests used an isolated shared-dialog fixture. These results are not a substitute for real-role staging tests, a penetration test or proof that the deployed system is vulnerability-free.

Keep Table 1's existing 15 selected cases as a selected summary if still accurate. Add a separate Romel security-test table or appendix using RM IDs from RomelRevisionsTest.pdf. Do not relabel all automated test methods as 15 cases or add test counts to survey respondent counts. Preserve the existing TAM and ISO respondent counts and results.

Where: Chapter IV > System Presentation (insert immediately after the module discussion)

Find: "The developed system reflects the research gap identified" | Source paragraph(s): 475

Insert a short subsection 'Sensitive-Document Protection and Security Regression Results'. Include the RM table, one redacted-password dialog screenshot, one protected reader password prompt, a private audit event without secrets, and a live cross-owner denial after staging verification. If a screenshot or live test is not yet available, label it outstanding; never replace it with fabricated evidence.

Suggested wording: Two narrowly scoped export issues were reproduced offline using baseline functions and synthetic data: official export handlers returned readable download bytes, and the applicant CSV builder retained a formula-prefixed cell value. The revision introduces protected official copies and formula-prefix escaping, with regression tests confirming the expected output. This does not establish that an anonymous user accessed data or that a historical attack succeeded. The available defense transcripts do not supply a reproducible exploit request, affected account list or penetration-test certification.

Use the baseline commit and test names in test-results/romel-baseline.json. Report the actual affected paths as /admin/reports/export (plaintext preparation) and the grantor applicant export pipeline (CSV output). Do not invent attacker identities, SQL-injection payloads, severity ratings or historical incidents.

R7. Preserve Honest Limits and Deployment Wording

Where: Chapter I > Scope and Limitations

Find: "The system implements authentication, authorization, private document access" | Source paragraph(s): 91

Action: add the new protected-download layer as a revised implementation while retaining the listed operational limitations. Do not remove malware, retention, backup/restore or field-level-encryption limitations because a download password was added.

Where: Chapter III > Development Environment / deployment safeguards

Find: "The deployed environment uses Supabase Auth for authentication" | Source paragraph(s): 428

Action: retain the sentence that technical review is not penetration-test certification. Do not claim the new migration or deployment is live until verified. Distinguish provider-managed Auth/TLS/hosting controls from the application's authorization, preview logic, encryption and audit mechanisms.

Where: Chapter V > Recommendations > privacy and security

Find: "The researchers also recommend further strengthening the system's privacy" | Source paragraph(s): 597

Suggested wording: The revised implementation adds password-protected official downloads and download-preparation auditing. Future improvements should focus on remaining controls, including dedicated malware scanning, formal retention/deletion policies, broader field-change auditing, improved abuse protection and regularly verified database-and-document recovery. Provider backup availability and application download encryption do not demonstrate that a complete restore procedure or universal multi-factor authentication has been implemented.

Control Classification to Keep in the Paper

Implemented in application	Provider-managed / verify configuration	Not established by this revision
Role/ownership checks; private document endpoints; protected copies; password-assisted processing; append-only preparation audit	Supabase Auth credentials/tokens; platform TLS; database/Storage infrastructure controls. Verify actual project policies and settings.	Universal MFA, malware scanning, full field encryption, uniform retention, all-field before/after audit, tested production backup recovery
CSV formula escaping is maintained separately	User's reader/archive program must support the encryption format	No screenshots/printing/password-sharing prevention or guaranteed runtime-memory zeroization

Plain-English Legend

Authentication: Checking who is signing in.

Authorization: Checking which records that person may use.

AES-256: The file-locking encryption selected for the downloaded copy; not the user's login system.

ZIP archive: A protected container. Extract its original-format files with the archive password.

SHA-256 fingerprint: A short identifier calculated from file bytes; it is not reversible file encryption.

OCR: Reading letters and numbers from document images.

Levenshtein similarity: Comparing text using the number of insertions, deletions and replacements needed to make the strings match.

Weighted Recommendation Scoring: Adding explained factor points to order scholarship suggestions.

RLS / service role: Database row-access rules / the privileged backend identity; service access still requires application ownership checks.

References and Evidence Still Needed

https://pypdf.readthedocs.io/en/6.1.1/user/encryption-decryption.html

https://pypi.org/project/pyzipper/

https://supabase.com/docs/guides/storage/security/access-control

https://supabase.com/docs/guides/security/platform-security

Outstanding: authenticated real-role browser checks, supported desktop/mobile PDF and AES ZIP readers, actual digital-signature verification, full report visual/count/history retest, staging advisors/grants and controlled release evidence. Keep any earlier deployed verification dated and separate from this local revision. The code/guide does not establish new real-document accuracy or production security findings.